1.1.1. Характеристики порушника

З інформаційної безпеки ви знаєте, що якщо користувач ресурсів ІКС здійснює спробу несанкціонованого доступу до об'єктів захисту (ознайомлення, модифікація, знищення, зміна режимів використання чи функціонування тощо), то такий користувач є порушником. Я розповім як використовується моделювання порушника для аналізу кібербезпеки.

Порушення безпеки бути як ненавмисними, так і зловмисними.

Слід очікувати, що порушники мають кваліфікацію, достатню для успішної реалізації загроз ресурсам ІКС , тобто володіють:

– інформацією про функціональні особливості ІКС, вміють користуватися штатними засобами;

– знаннями та досвідом праці та обслуговування з такими ж технічними засобами, які є в ІКС ;

– знаннями у галузі обчислювальної техніки та програмування на мовах розробки програмних засобів ІКС, проектуванню та експлуатації подібних до ІКС систем;

– інформацією про функції та механізми захисту, які є реалізованими як у Системі технічного захисту інформації ІКС, так і про функції та механізми захисту, які є вбудованими в базове та прикладне програмне забезпечення.

По рівню можливостей, які надаються їм штатними засобами комп'ютерної мережі виділяються чотири рівня можливостей порушників.

– перший рівень визначає найнижчий рівень можливостей у комп'ютерній системі – для отримання потрібної порушнику інформації – можливість запуску фіксованого набору програм, які реалізують заздалегідь визначені функції з обробки інформації;

– другий рівень визначається можливістю створення та запуску власних програм із новими функціями з отримання та обробки потрібної порушнику інформації;

– третій рівень визначається можливістю управління функціонуванням КС, тобто впливом на базове програмне забезпечення системи, а також на склад і конфігурацію технічного забезпечення;

– четвертий рівень визначається всім об’ємом можливостей людей, що здійснюють проектування, реалізацію та ремонт технічних засобів комп’ютерної системи, включаючи введення до її складу власних технічних засобів із новими функціями з обробки інформації.

Метою порушника–зловмисника може бути:

– авторизуватися особисто, тобто отримати особисті легальні атрибути доступу з бажано найширшими правами щодо доступу до ресурсів ІКС з метою їх використання, отримання необхідної інформації у потрібному обсязі та асортименті, ознайомлення з конфіденційною інформацією, її модифікації (внесення змін в інформаційні потоки) чи знищення у відповідності зі своїми намірами (інтересами, планами);

– авторизувати своїх прихильників чи довірених осіб, які б мали змогу отримати легальні атрибути доступу з бажано найширшими правами щодо доступу до ресурсів ІКС;

– мати прихильників чи довірених осіб серед персоналу чи користувачів ІКС, які мають змогу отримувати легальні атрибути доступу з бажано найширшими правами щодо доступу до ресурсів ІКС і можуть їх використовувати, отримувати бажано конфіденційну інформацію, її модифікувати чи знищувати;

– при відсутності змоги чи безуспішності реалізації попередніх пунктів реалізації спроб щодо:

– здобуття атрибутів доступу авторизованих користувачів шляхом використання технічних засобів, крадіжок, купівлі, чи отримання іншим шляхом;

– проникнення на місця розміщення тих чи інших компонентів, елементів чи ресурсів ІКС;

– зміни режимів функціонування чи виводу з ладу фізичних ресурсів ІКС;

– встановлення фізичних засобів в місцях розміщення елементів ІКС;

– встановлення фізичних засобів в місцях розміщення елементів ІКС (технічних закладок) для генерації несправжніх сигналів, інформаційних символів чи повідомлень;

– встановлення програмних засобів (програмних закладок чи вірусів) зняття інформації з метою її того чи іншого використання;

– встановлення програмних засобів (програмних закладок чи вірусів) для модифікації як програмних засобів, так і інформації ІКС шляхом генерації (впровадження) програмних вірусів, несправжніх сигналів, інформаційних символів чи повідомлень із метою перевантаження систем ІКС і порушення, таким чином, доступності компонентів ІКС чи ІКС в цілому;

– здійснення спроб несанкціонованого доступу до обчислювальних ресурсів, інформаційних ресурсів, базового та прикладного програмного забезпечення та програмного забезпечення системи ТЗІ як власне ІКС , так і її телекомунікаційної підсистеми шляхом подолання системи управління доступом.

Порушник може знати:

1. Склад, розміщення, функціональні особливості, умови та режими функціонування елементів ІКС.

2. Порядок, засоби та режими здійснення організаційно правових та технічних заходів захисту ресурсів ІКС.

3. Основні закономірності формування в ІКС, баз даних та потоків запитів до них.

За характером дій зловмисник може здійснювати активні чи пасивні дії (загрози) ресурсам та функціональним властивостям захищеності інформаційних об’єктам (спрямованість загроз) ІКС. Під активною загрозою розуміється спроба навмисної несанкціонованої зміни стану ІКС, а під пасивною загрозою – спроба несанкціонованого проникнення в систему без зміни її стану.

За характером дій порушників можна класифікувати на:

– “випадкових порушників” – авторизованих користувачів, які порушили політику безпеки тієї чи іншої послуги ненавмисно, а помилково шляхом виконання непередбачених дій з об’єктом захисту шляхом випадкового

подолання засобів управління (адміністрування) доступом до нього тощо. Такий порушник може здійснювати випадкові загрози ресурсам ІКС під час виконання своїх функціональних обов'язків внаслідок помилкових дій, за рахунок неуважності чи недбалості;

– "зловмисників, яких можна терпіти" – авторизованих користувачів, які порушили політику безпеки тієї чи іншої послуги навмисно, але без рішучих дій, маскуючись, шляхом підбору атрибутів доступу інших користувачів із метою прихованого подолання засобів управління (адміністрування) доступом до нього тощо;

– "рішучих зловмисників", які мають на меті будь-що порушити ту чи іншу властивість захищеної інформації. Для цього такі зловмисники прагнуть подолати засоби організаційного обмеження доступу, охоронної сигналізації, управління доступом до фізичних ресурсів тощо і отримати змогу фізичного доступу до засобів оброблення, зберігання чи передавання інформаційних об'єктів;

– зловмисників, які використовують засоби віддаленого доступу до інформаційних об'єктів.

Дії порушників можуть бути спрямованими на порушення функціональних властивостей захищеності інформаційних об'єктів, зокрема на порушення:

– конфіденційності, цілісності та доступності інформаційних об'єктів;

– можливості спостереження за діяльністю користувачів і процесів, однозначної ідентифікації причепних до подій користувачів і процесів.

За використовуваними методами й способами *порушники можуть використовувати:*

– агентурні методи одержання відомостей;

– пасивні технічні засоби перехоплення інформаційних сигналів;

– штатні засоби ІКС або недоліки проектування Системи захисту інформації від НСД до конфіденційної інформації для реалізації спроб НСД;

– способи і засоби активного впливу на елементи ІКС, що змінюють конфігурацію ІКС (підключення додаткових або модифікація штатних

технічних засобів, підключення чи “врізання” у канали передачі даних, впровадження й використання спеціального ПЗ тощо).

1.1.2. Неформальна модель порушника

Порушник – це особа, що зробила спробу виконання заборонених операцій (дій) або помилково і незнанню, або усвідомлено із злим наміром (з корисливих інтересів) або без такого (ради гри або задоволення, з метою самоствердження і тому подібне) з використанням для цього різних можливостей, методів і засобів.

Зловмисником називатимемо порушника, що навмисно йде на порушення з корисливих мотивів.

Модель порушника відображає його практичні і теоретичні можливості, апріорні знання, час і місце дії і тому подібне. Для досягнення своїх цілей порушник повинен докласти зусилля, витратити певні ресурси. Дослідивши причини порушень, можна або вплинути на ці причини, або точніше визначити вимоги до системи захисту від даного виду порушень або злочинів. У кожному конкретному випадку виходячи з існуючої технології обробки інформації може бути визначена модель порушника, яка повинна бути адекватна реальному порушникові для даної ІКС.

При розробці моделі порушника формуються:

– припущення про категорії осіб, до яких може належати порушник;
– припущення про мотиви (цілях) порушника;
– припущення про кваліфікацію порушника і його технічної оснащеності;
– обмеження і припущення про характер можливих дій порушників.

По відношенню до ІКС порушники бувають внутрішніми (з числа персоналу) або зовнішніми (сторонні особи).

Внутрішніми порушниками можуть бути:

– користувачі (оператори) системи;
– персонал, обслуговуючий технічні засоби (інженери, техніки);
– співробітники відділів розробки і супроводу ПЗ (прикладні і системні програмісти);

– технічний персонал, обслуговуючий будівлі (прибиральники, електрики, сантехніки і інші співробітники, що мають доступ в будівлі і приміщення, де розташовані компоненти ІКС);

– співробітники служби безпеки ІКС;

– керівники різних рівнів посадової ієрархії.

Сторонніми порушниками можуть бути:

– клієнти;

– випадкові відвідувачі;

– представники підприємств, що забезпечують енерго-, водо- і теплопостачання організації;

– представники конкуруючих організацій (іноземних спецслужб) або особи, що діють за їх завданням;

– будь-які особи за межами контрольованої території.

Можна виділити три основні мотиви порушень безпеки ІКС з боку користувачів: безвідповідальність, самоствердження і корисливий інтерес. При порушеннях, викликаних безвідповідальністю, користувач цілеспрямовано або випадково проводить які-небудь руйнуючі дії, не пов'язані проте із злим наміром. В більшості випадків це наслідок некомпетентності або недбалості. Деякі користувачі вважають надбання доступу до системних наборів даних великим успіхом, затіваючи свого роду гру «проти системи» заради самоствердження.

Порушення безпеки ІКС може бути викликано і корисливим інтересом користувача системи. В цьому випадку він цілеспрямовано намагатиметься подолати систему захисту для доступу до інформації, що зберігається, передається та оброблюється в ІКС.

Як ви знаєте з основ захисту інформації, Модель порушника – це всебічна структурна характеристика порушника, яка є частиною моделі загроз та використовується під час розроблення політики безпеки інформації

Модель порушника відображає його практичні та потенційні можливості, апріорні знання, час та місце дії тощо. Модель порушника, яку побудовано з урахуванням особливостей власної ІТС (що забезпечує певне виконання технологічних процесів створення об’єкту захисту), технологій обробки інформації, категорій персоналу та користувачів характеризується сукупністю значень характеристик, що наведені вище. Сукупність цих характеристик визначає профіль можливостей порушника.

При забезпеченні інформаційної безпеки необхідно дослідити ланцюжок від потенційного зловмисника, наявної вразливості, загрози її використання, безпосередньої дії (атаки) та її наслідків.

Класифікація загроз охоплює сукупність можливих варіантів дій джерел загроз, які призводять до реалізації цілей атаки. Мета атаки може не співпадати з метою реалізації загроз і може бути направлена на отримання проміжного результату, необхідного для досягнення надалі реалізації загрози. У разі такого незбігу атака розглядається як етап підготовки до здійснення дій, направлених на реалізацію загрози, тобто як «підготовка до здійснення» протиправної дії. Завдяки такому підходу можливо:

- встановити пріоритети цілей безпеки;
- визначити перелік актуальних джерел загроз;
- визначити перелік актуальних вразливостей;
- оцінити взаємозв'язок загроз, джерел загроз і вразливостей;
- визначити перелік можливих атак на об'єкт;
- описати можливі наслідки реалізації загроз.

Результати проведення оцінки і аналізу можуть бути використані при виборі адекватних оптимальних методів протидії загрозам, а також при аудиті реального стану інформаційної безпеки об'єкту для цілей його страхування.

При визначенні актуальних загроз, експертно-аналітичним методом визначаються об'єкти захисту, схильні до дії тієї або іншої загрози, характерні джерела цих загроз і уразливості, які сприяють реалізації загроз. На підставі аналізу складається матриця взаємозв'язку джерел загроз і вразливостей з якої визначаються можливі наслідки реалізації загроз (атаки) і обчислюється коефіцієнт небезпеки цих атак як добуток коефіцієнтів небезпеки відповідних загроз і джерел загроз, визначених раніше.

Аналіз потенційно можливих загроз інформації є одним з перших і обов'язковим етапом розробки будь-якої захищеної інформаційної системи. При цьому складається якомога повніша сукупність загроз, аналізується ступінь ризики при реалізації тієї або іншої загрози, після чого визначаються напрями захисту інформації в конкретній системі.

Краще всього аналізувати наслідки реалізації загроз ще на стадії проектування локальної мережі, робочого місця або інформаційної системи, щоб заздалегідь визначити потенційні втрати і встановити вимоги до заходів забезпечення безпеки. Вибір захисних і контрольних заходів на ранній стадії проектування ІКС вимагає набагато менших витрат, чим виконання подібної роботи на експлуатованій ІКС.

Модель STRIDE (за першими буквами назв категорій) була розроблена фірмою Microsoft і майже 20 років успішно застосовується для визначення та «зважування» загроз [6]. STRIDE базується на класифікації загроз безпеці по наступних шести категоріях:

1) *Підміна мережевих об'єктів (Spoofing identity)*. Атаки подібного типу дозволяють зловмисникові видавати себе за іншого користувача або підміняти справжній сервер підробленим. Приклад підміни особи користувача – використання чужих автентифікаційних даних (імені користувача, пароля) для атаки на систему.

2) *Модифікація даних (Tampering with data)*. Атаки цього типу порушують цілісність даних, що зберігаються, обробляються чи передаються. Приклади: несанкціоновані зміни даних (наприклад, що зберігаються в базі даних).

3) *Відмова від авторства (Repudiation)*. Легальний користувач може виконати певну операцію і відмовитися від її «авторства», а адміністраторові не вдасться нічого довести в разі відсутності чи несправності механізмів аудиту та протоколювання дій користувачів.

4) *Розголошування інформації (Information disclosure)*. Мається на увазі розкриття інформації особам, доступ до якої їм заборонений, тобто, порушення конфіденційності.

5) *Відмова в обслуговуванні (Denial of service)*. В атаках такого типу зловмисник намагається позбавити доступу до сервісу правомочних користувачів, наприклад, зробивши веб-сервер тимчасово недоступним або непридатним для роботи.

6) *Підвищення привілеїв (Elevation of privilege)*. В даному випадку непривілейований користувач дістає привілейований доступ, що дозволяє йому «проникнути» в систему – отримати конфіденційну інформацію, підмінити чи впровадити власний програмний код, чи знищити систему.

У табл. 1 перераховані методи, які застосовуються для боротьби з небезпеками, описаними в моделі STRIDE. Запропоновані засоби боротьби з загрозами можна звести до наступних:

- автентифікація користувачів;
- розподіл повноважень (авторизація);
- захист від несанкціонованого доступу;
- аудит;
- фільтрація.

Таблиця 1. Основні методи боротьби з загрозами.

Тип небезпеки	Засоби боротьби
Підміна мережевих об'єктів (S)	– Надійний механізм автентифікації – Захист секретних даних – Відмова від зберігання секретів

Модифікація даних (T)	– Надійний механізм авторизації – Використання хеш-кодувань – MAC-коди – Цифрові підписи – Протоколи, що запобігають прослуховуванню трафіку
Відмова від авторства (R)	– Цифрові підписи – Мітки дати і часу – Контрольні сліди
Розголошування інформації (I)	– Авторизація – Протоколи з посиленим захистом від несанкціонованого доступу – Шифрування – Захист секретів – Відмова від зберігання секретів
Відмова в обслуговуванні (D)	– Надійний механізм автентифікації – Надійний механізм авторизації – Фільтрація – Управління числом вхідних запитів – Якість обслуговування
Підвищення рівня привілеїв (E)	– Виконання з мінімальними привілеями

М. Ховардом і Д. Лебланком був запропонований один з способів оцінки ризиків – DREAD [7], який також названий за першими буквами п’яти категорій:

1) *Потенційний збиток (Damage potential)* – міра реального збитку від успішної атаки. Найвищий ступінь небезпеки означає практично безперешкодний злом засобів захисту і виконання практично будь-яких операцій. Підвищенню привілеїв зазвичай привласнюють оцінку 10. У інших ситуаціях оцінка залежить від цінності даних, що захищаються.

2) *Відтворюваність (Reproducibility)* – міра можливості реалізації загрози. Деякі вразливості доступні постійно, інші – тільки залежно від ситуації, і їх доступність непередбачувана, тобто не можна напевно знати, наскільки успішною виявиться атака. Наприклад, вразливості, знайдені у типовому програмному забезпеченні, характеризуються високою відтворюваністю.

3) *Легкість організації атаки (Exploitability)* – міра зусиль і кваліфікації, необхідних для проведення атаки. Так, якщо її може реалізувати недосвідчений програміст на домашньому комп'ютері – 10. Якщо ж для її проведення треба витратити 100 млн. доларів, оцінка небезпеки –

1. Атака, для якої можна написати алгоритм (а значить, розповсюдити у вигляді сценарію серед любителів), також оцінюється в 10 балів. Слід також враховувати необхідний для атаки рівень автентифікації і авторизації в системі. Наприклад, якщо це доступно будь-якому видаленому анонімному користувачеві, подібна небезпека оцінюється 10 балами; Іноді небезпека стає реальною тільки в системі, яка конфігурована особливим чином;

4) *Коло користувачів, що потрапляють під удар (Affected users)* – частка користувачів, робота яких порушується із-за успішної атаки. Оцінка виконується на основі процентної частки: 100% всіх користувачів відповідає оцінка 10, а 10% – 1 бал.

5) *Важкість виявлення (Discoverability)* – наскільки швидко і чи взагалі можна виявити факт реалізації загрози. Вважається найскладнішою для визначення оцінкою.

Інтегральний ризик в методиці DREAD оцінюється за формулою

$$R = \frac{R_{Dam} + R_R + R_E + R_A + R_{Dis}}{5}, \qquad (1)$$

де R з індексом – чисельні оцінки відповідних типів ризику.

Подекуди в методику DREAD включають ще один показник – *витрати* на усунення наслідків успішної атаки, умовно названий X (*eXpense*). Таким чином, для кількісної оцінки ризику використовується модель DREADX і сумарна DREADX-оцінка дорівнює сумі всіх оцінок, поділеній на шість).

З урахуванням пояснень до оцінки ризиків DREAD та запропонованої класифікації конкретних загроз, спробуємо скласти матрицю ризиків шляхом поєднання класифікації загроз STRIDE та оцінки ризиків DREAD. Як запропоновано в моделі DREAD, оцінки для кожної з загроз будуть виставлені, як і запропоновано в моделі DREAD, від 0 до 10, таким чином, що 10 означатиме високу ймовірність настання певного наслідку від реалізації даної загрози, а 0 – або відсутність наслідку або невластивість подібної загрози при атаках типу. Приклад такої оцінки наведено в табл. 1, а також на рис.1 та рис.2. Для демонстрації застосовано примірні оцінки вигаданого кіберінцидента. Ці результати можна візуалізувати у вигляді двох діаграм: на які ризики впливає певний тип загрози (рис.1) і які загрози є складовими в оцінці певного фактору ризику (рис.2).

Таблиця 1. Оцінка загроз за факторами ризику.

	R_{Dam}	R_R	R_E	R_A	R_{Dis}	**Інтегральний ризик (1).**
S	10	5	5	10	9	7,8
T	10	4	1	8	5	5,8
R	10	4	1	8	5	5,8
I	5	5	5	10	5	6
D	8	8	8	10	0	6,8

E	0	0	0	0	0	0
Сума по категоріях	43	26	20	46	24	32.2

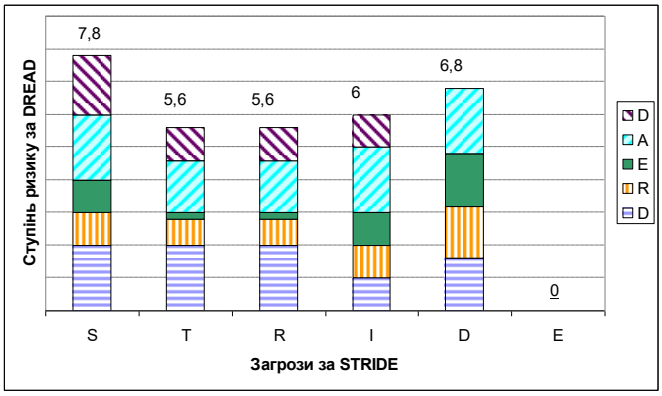

Рис. 1. Оцінка загроз від атак по методу STRIDE за факторами ризику DREAD.

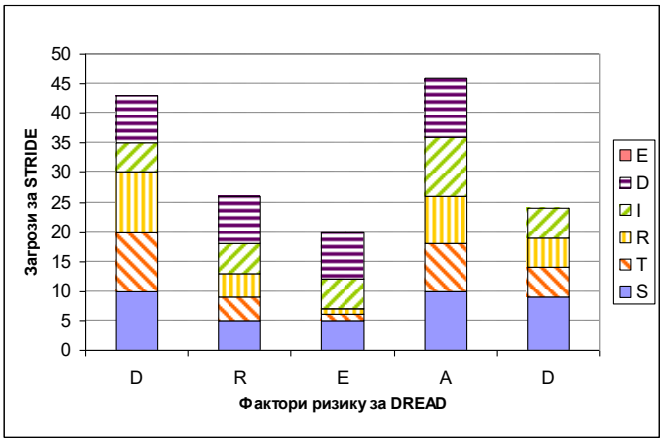

Рис. 2. Вага загроз STRIDE в оцінці різних ризиків від атак.